

Scruple — Generator Product Conformance Program re-submission (GPSA v3)

From: Shaun Hargadine **Date:** 2026-08-04 **Re:** Resubmission addressing the 2026-08-04 GPSA Reviewer report; Level 2 conformance **Intake record ID:** 019f5856-bff8-7f57-a879-80594a6fb3fe

Dear Scott,

Thank you for the detailed report on 2026-08-04. This resubmission addresses each nonconformity in full — GPSA rewritten, code changes shipped and unit-tested, samples bundle restructured per your specification. Filed at **Assurance Level 2** against the C2PA Generator Product Security Requirements v0.1.

Attached bundle: scruple-c2pa-conformance-2026-07-30.zip

Nonconformity remediation

Req 6.3.2 + 6.4.2 — OS Patch Recency (was: DOES NOT MEET)

You correctly noted that our prior approach (60-day CVM rotation with instance-age as the freshness metric) was an operational proxy, not a direct extract-and-validate of the OS security patch date.

What we shipped:

1. **Real per-sign OS-patch-date extractor.** New module `services/c2pa-signer/os_patch_check.py` reads the running instance's package-manager history (`dnf.rpm.log` on Oracle Linux, `apt/history.log` fallback) and returns the timestamp of the most recent package install/upgrade as the `os_security_patch_date`.
2. **Per-sign 90-day gate.** On every `C_Sign` call, the Signer evaluates `patch_recency_verdict()` and refuses to sign if `now - os_security_patch_date > 90` days. Fail-closed in production (unset extractor → refuse). See `services/c2pa-signer/sign.py:120-136`.
3. **Bound into every signed manifest.** The `ai.scruple.signer-runtime.v1` assertion now carries `os_security_patch_date`, `os_security_patch_age_days`, `os_security_patch_max_age_days`, and `os_security_patch_source`. A verifier can compute `now - os_security_patch_date` and confirm independently that the Signer was within the 90-day window when it signed.
4. **13 unit tests** at `services/c2pa-signer/tests/test_os_patch_check.py` covering both ISO-8601 `dnf` format and Ubuntu `apt` history format; fresh vs stale; dev vs production fail-closed policy; configurable threshold via `SCRUPLE_OS_PATCH_MAX_AGE_DAYS` env var.

The 60-day CVM rotation is retained as an operational belt-and-braces that keeps the per-sign check trivially satisfied under normal operation, but it is no longer the primary control for these requirements. GPSA §C.2.3.0 has the full design.

Req 6.3.1 — Assertion Provenance / TOE Boundary (was: DOES NOT MEET)

You called out that the earlier description (“third-party generator products that delegate signing to Scruple”) risked signing over created_assertions originating outside our TOE.

What we shipped:

1. **GPSA §C.1.3 rewritten** to state that every created_assertions entry on a Scruple-signed manifest is authored by code executing inside the attested Signer CVM TOE. The “delegated signing on behalf of a third-party generator” mode is explicitly ruled out — every signing pass constructs its own manifest from Client request parameters, inside the TOE, under Scruple’s control.
2. **GPSA §C.2.4 adds an explicit assertion-provenance boundary section** describing how assertion labels partition into created_assertions (Scruple-authored) vs gathered_assertions (external-provenance, honestly labeled).
3. **Code enforcement:** new module services/c2pa-signer/assertion_partition.py partitions incoming assertion labels at the API boundary. A whitelist of C2PA-standard labels + the Scruple-namespaced runtime assertion is allowed into created_assertions. A separate whitelist of explicit external-provenance labels (schema.org, IPTC, EXIF) is allowed into gathered_assertions. Any label outside both whitelists causes the Signer to refuse to sign (fail-closed). Wired into sign.py:177-193. Per-manifest audit log line for §C.2.6.
4. **10 unit tests** at services/c2pa-signer/tests/test_assertion_partition.py covering created/gathered partition, unknown-label refusal, version-suffix normalization.

Samples bundle — restructured per your specification

- **Part-1-Media-Samples/generate/** — signed C2PA outputs, one file per asserted generate media type (16 MIMEs supported today; 2 gaps documented below).
- **Part-1-Media-Samples/validate/raw/** — 20 raw input files covering every asserted ingest media type.
- **Part-1-Media-Samples/validate/ingested/** — 20 post-ingest signed derivatives, one per asserted validate media type.
- **All .json sidecars removed** from Part-1-Media-Samples/.
- **Part-2-Runtime-Assertion-Sample/ removed** as redundant — the runtime assertion is now embedded in every Part-1 signed asset per the fixes above.

Confirmations

- **Target assurance:** Level 2 (implicit Level 1 conformance).
- **Product name:** Scruple.
- **Product role:** Generator Product, Distributed implementation class.

Documented gaps

Two MIMEs (application/pdf, application/x-pytorch) cannot yet be signed by the c2pa-python 0.89 wrapper we use in our sample producer. Raw samples are provided at Part-1-Media-Samples/validate/raw/. Signed samples will follow when the wrapper exposes those features. The underlying c2pa-rs supports both.

Sample validation

Every included signed sample independently verifies as validation_state=Valid via a fresh c2pa.Reader against the included development cert chain (02-dev-root-ca.pem and 03-dev-signer-cert.pem). Cross-implementation validation against a third-party C2PA sample set (external-c2pa-samples/) has been run end-to-end; per-sample reports at trust-validation-results/.

Reproducibility

The bundle producer, signer (including the new patch-recency extractor and assertion partition), validator, rotation Function, IAM policies, and CI workflows are in the public repository at github.com/Docenttx/Scruple/. The specific commit corresponding to this submission is captured in security-architecture/evidence/README.md.

Next steps

Ready for the next review pass. Happy to walk any of the above through a video-conference review at your convenience.

Best regards,

Shaun Hargadine Docent LLC (dba Docent Tech)

- Contact: scruple@docentechs.com
- Public product site: scruple.ai